h2 Scene – Homework Report

a) Podcast – Darknet Diaries, Episode 174: “Pacific Rim”

Podcast: Darknet Diaries by Jack Rhysider.
Episode 174: “Pacific Rim” — Sophos’s six-year covert operation against a state-backed group targeting its firewalls.

Summary

- For six years, Sophos was quietly fighting a state-backed group linked to China that was breaking into Sophos firewalls. These are perimeter devices protecting thousands of customer networks. This was not one break-in. It was a sustained campaign over years, with operations named Cloud Snooper and Asnarök, plus undisclosed activity grouped under “Pacific Rim.”

- Sophos disrupted nine zero-day attacks, exposed who was behind them, and forced the attackers to change tactics.

- The part that stayed with me, and this is where the police background kicks in, is the command decision. Sophos did not just defend. They went on the offensive, covertly. The episode asks bluntly: was it ethical? Was it effective? They had to overhaul their own defensive posture, but at what cost? In my old job, we called this “proactive intervention.” Sometimes you do not wait for the crime. But there is always a line, and someone has to decide where it sits and who carries the weight when it goes wrong.

- What the episode really describes is a private company rewriting its own threat model, moving from passive defense to active disruption. That is a different risk posture entirely, and it is not obvious that a standard “identify, assess, mitigate” cycle can capture the governance question underneath it.

- My own idea/question: Who authorizes a covert operation like this, and who is accountable afterwards? In policing, that chain is written down. In corporate security, it often is not. That gap is worth a thesis on its own.

Source: Darknet Diaries, EP 174 “Pacific Rim” https://darknetdiaries.com/episode/174/

b) Blog – Unit 42, 2026 Global Incident Response Report summary

Blog: Unit 42 (Palo Alto Networks).
Post: AI-Accelerated Attacks, Identity-Enabled Breaches and Expanding Software Supply Chain Exposure Define the 2026 Cyberthreat Landscape (Feb 2026).

Summary

- Unit 42 analyzed over 750 major incidents across more than 50 countries. That is a large enough sample to see patterns, not just anecdotes.

- Attacks are 4× faster. In the fastest cases, attackers went from initial access to data exfiltration in 72 minutes. AI is doing the heavy lifting in reconnaissance, phishing, scripting, and execution. In police work, we talked about the “golden hour” after a crime the window to catch the trail. In cyber, that window has almost closed.

- Identity is the primary attack vehicle. Identity weaknesses were material in nearly 90% of investigations. Attackers log in with stolen credentials and tokens rather than breaking in. That matters, because perimeter thinking is often looking in the wrong place.

- Supply chain risk drives operational disruption. In 23% of incidents, attackers abused third-party SaaS applications, trusted integrations, vendor tools, and dependencies. They bypass the front door by going through a supplier that is already inside.

- Attack complexity is growing. 87% of intrusions spanned multiple surfaces: endpoints, networks, cloud, SaaS, and identity. You cannot defend one layer and call it done.

- The browser is a primary battleground. Nearly 48% of incidents included browser-based activity.

- Extortion is moving beyond encryption. Encryption-based extortion declined 15%, as attackers skip encryption and go straight to data theft and disruption.

- Most breaches succeed because of exposure, not sophistication. In over 90% of incidents, misconfigurations or coverage gaps enabled the attack. That is a familiar story from my old job too: it is rarely the brilliant criminal who gets through; it is the unlocked door everyone walked past for months.

- My own idea/question: If 90% of incidents involve identity weaknesses, threat modeling should treat identity infrastructure, not just applications, as a primary asset. In police terms, it is the difference between guarding the vault and checking who has the keys.

Source: Unit 42, 2026 Global Incident Response Report* summary, 20 Feb 2026 https://live.paloaltonetworks.com/t5/blogs/blogarticleprintpage/blog-id/CommunityBlog/article-id/3845

c) Science that – linking h1 theory to a fresh security event

- h1 article used: Khalil, S. M., Bahsi, H., & Korõtko, T. (2024). Threat modeling of industrial control systems: A systematic literature review. Computers & Security, 136, 103543. https://doi.org/10.1016/j.cose.2023.103543

- Fresh security event: The December 2025 attack on Poland’s energy sector, reported by CERT Polska and amplified by CISA in February 2026. Attackers compromised OT and ICS at renewable energy plants, a combined heat and

power plant, and a manufacturing company. Initial access came through vulnerable internet-facing edge devices; the attackers deployed wiper malware, damaged remote terminal units (RTUs), destroyed data on HMIs, and corrupted firmware on OT devices. Operators lost view and control between facilities and the distribution system operator, even though renewable generation continued. A parallel attack on a smaller CHP plant used a private APN pivot from a Fortinet VPN device to a Teltonika cellular router, through an SSH tunnel into the DSO's private APN, and on to a Wago PLC shutting down a steam turbine and a water treatment system. The plant initially thought it was an engineering error.

Link to the h1 theory

- Khalil et al. argue that ICS threat modeling must use structured, methodical frameworks covering safety and security together, and they flag a validation gap: many proposed methodologies have never been proven in real operational environments.

- The Poland incident is the validation gap made visible. The attack did not target data. It targeted the control and safety layer: RTUs, HMIs, PLCs, firmware. That is exactly the safety–security integration the review says threat modeling must handle. And the fact that the CHP disruption was first mistaken for an engineering error tells you something uncomfortable: the defenders did not have a threat model that predicted this path. They discovered it after the fact.

- The private APN pivot is the detail I keep coming back to. The attackers did not break into the PLC directly. They walked through a chain of trusted connections: edge device, cellular router, private APN, controller. That is the same structural lesson the H1 review points to when it warns that ICS security must be treated as a whole system, not as isolated devices. The risk lives in the connections and the trust layers, not just in the components.

- The Unit 42 data adds the larger picture: 23% of incidents now involve supply-chain abuse, and Dragos reports that engineering firms, integrators, and OT equipment vendors were heavily targeted in 2025, with 1,020 industrial ransomware incidents in Q1 2026 alone. The Poland case fits that pattern: edge devices and communication paths are the soft spots, and they are shared across operators.

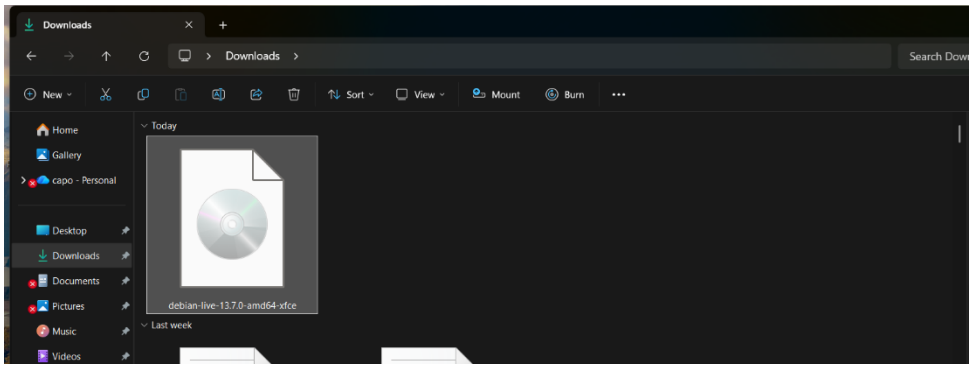
- The Triton episode (Darknet Diaries EP 68) is the historical anchor for this. In 2017, attackers went after a Triconex safety-instrumented system in a Saudi petrochemical plant the safety layer itself. Poland 2025 is the same idea, scaled and updated: the target is not confidentiality; it is control and physical process integrity. Triton makes the Poland event legible; Poland makes Triton look like a warning that was not fully acted on.

- My own question: If edge devices and private APNs are repeatedly the path into OT, should threat modeling frameworks for critical infrastructure treat communication paths and third-party edge devices as first-class safety assets,

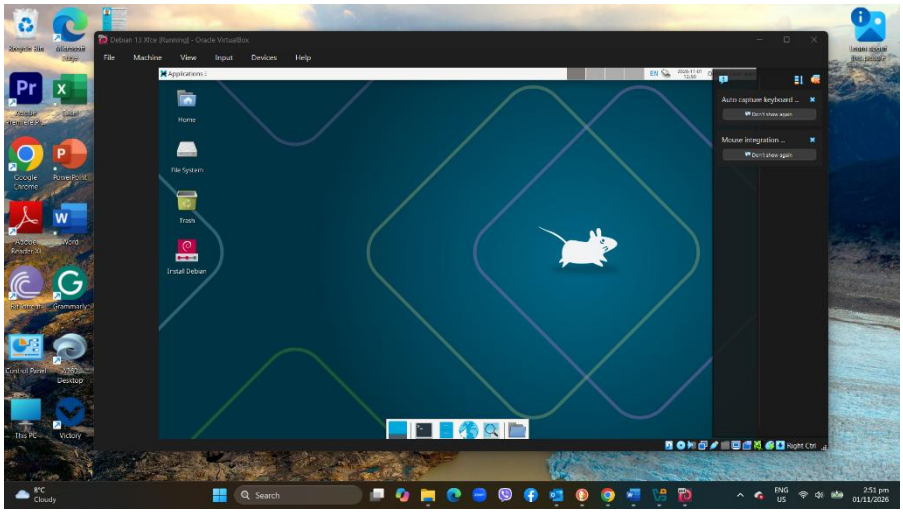
not as secondary implementation details? In my old line of work, we protected what actually mattered, not just what looked important on the org chart.

Sources: Khalil et al. 2024 (h1 article); CISA alert, 10 Feb 2026 ; SecurityWeek, “Novel Private APN Pivo”, Aug 2026; CERT Polska Energy Sector Incident Report, 29 Dec 2025; Dragos 2026 OT Cybersecurity Year in Review; Darknet Diaries EP 68 “Triton.”

d) Debian 13 “Trixie” live image – downloaded



e) Voluntary bonus – Debian install on a VM



AI disclosure: I used an AI assistant to help locate a suitable fresh ICS/OT incident and to cross-check the CISA and CERT Polska details. Prompt: Find a recent 2025 – 2026 ICS/OT incident suitable for linking to a systematic review on ICS threat modeling. I verified every factual claim used above against the CISA alert and the CERT Polska report before writing it in my own words.